

外部攻擊面治理月報 — 2026 年 4 月

匿名化 sample • 不含真實客戶資料

本月 KPI

範圍 DOMAIN 數 42 主域 + 子網域,含 SaaS 整合面	P0 任務數 3 本月新增 1 • 已修 2 • 待處理 3
平均分數變化 +4.2 月初 78.5 → 月末 82.7(滿分 100)	法規對應條目 12 資安法 5 • 個資法 3 • ISO 27001 4

風險趨勢

本月外部評分從月初 78.5 上升至月末 82.7,主要由於 acme-edge-01 憑證更新與兩個過期子網域的下架。Top Backlog 從 7 項收斂至 5 項; 新增 1 項 P0(payment 端點 TLS 1.0 殘留)。

備註:本月報為 sample 資料,實際客戶月報會內嵌平台產生的趨勢圖、熱區雷達與 90 天滾動歷史比較。

Top 5 高風險 Domain

Domain	分類	風險摘要	等級
acme-payment.example.com	支付閘道	TLS 1.0 殘留;PCI DSS 合規風險。	P0
acme-edge-01.example.com	邊緣節點	憑證 SAN 不一致,可能造成客戶端錯誤。	P1
portal.acme.example.com	客戶入口	未強制 HSTS,SecurityHeaders C 級。	P1
legacy-api.acme.example.com	舊版 API	建議於下季下架;仍有少量第三方流量。	P2
marketing.acme.example.com	行銷站	WordPress 外掛版本落後 4 個 minor。	P2

法規對應彙整

本月新發現的 5 項 P0/P1 風險,可對應到下列法規條目。完整對應表會 附在實際客戶月報的附錄。

資通安全管理法	個人資料保護法	ISO 27001:2022
弱點掃描與修補時效要求	技術與組織保護措施	A.8 技術控制 — 弱點管理
稽核紀錄保存與審查週期	個資處理目的與最小化原則	A.5 組織控制 — 治理結構
資安治理組織與責任歸屬	外洩通報與當事人告知	A.5.23 雲端服務與第三方風險

ROI 試算

本月修補 2 項 P0(acme-edge-01 憑證、過期子網域下架),依事件機率 與處理工時推估,等同延後或避免一輪內部資安事件處理流程。實際客戶 月報會根據業主指定的事件成本模型(例如 NIST CSF、業主自訂工時 單價)計算當月節省比例,並於季度治理檢討會議中累計年度回收率。

本月行動項

- P0 acme-payment.example.com:下週前停用 TLS 1.0,改用 TLS 1.2+ 並補上 HSTS。Owner:支付平台 SRE。
- P1 portal.acme.example.com:本月內補上 HSTS、CSP header,目標 SecurityHeaders B 級。Owner:Web Ops。
- P2 legacy-api.acme.example.com:下季啟動下架流程,先送停用通知給 仍在使用的第三方。Owner:API 平台。
- 風險溝通:把本月 P0 修補成果納入下次資安委員會簡報。Owner:CISO Office。

本月報為產品 *sample*,實際客戶月報依範圍客製 (Domain 數量、整合的外部評分平台、法規對應深度皆可調整)。